VIVA AEROBUS · GENERIC API · PROPUESTA

Control de calidad automático y propio para el código de Viva

Un revisor automático para cada cambio de código

SonarQube analiza el código fuente con reglas por lenguaje y señala los problemas antes de que un cambio se integre a la rama principal. Existe como servicio en la nube (SonarQube Cloud) o instalado en servidores propios (SonarQube Server).

QUÉ REVISA

Confiabilidad
Defectos que pueden hacer fallar el sistema en ejecución.

Seguridad
Vulnerabilidades, y código sensible (**security hotspots**) que Sonar marca para que el equipo lo revise.

Mantenibilidad
Código difícil de entender o de cambiar, y código duplicado.

Cobertura
Qué parte del código recorren las pruebas unitarias, **medida cuando el pipeline las ejecuta**.

CÓMO APORTA A LA CALIDAD

Perfil de reglas · Quality Profile
Qué reglas se aplican en cada lenguaje. Se define una vez y queda por defecto para todos los proyectos.

Filtro de calidad · Quality Gate
Los umbrales que un cambio debe cumplir. El resultado es uno solo: aprobado o fallido.

Foco en el código nuevo
Se exige a lo nuevo o modificado: la calidad mejora con cada cambio, sin frenar por lo existente.

En el día a día: el resultado **aparece en el propio cambio de código en GitHub**, con el detalle de cada problema. **Lo que no hace:** no reemplaza la revisión de una persona ni las pruebas funcionales; no sabe si el código hace lo que el negocio necesita. Documentación oficial: **docs.sonarsource.com/sonarqube-cloud**

Lo que Sonar puede medir, del plan base al completo

VIENE CON SONARQUBE CLOUD

Calidad y seguridad del código propio

- **SAST:** revisa el código fuente sin ejecutarlo. Detecta inyección SQL, cross-site scripting, deserialización insegura y más, con reglas **mapeadas** a **OWASP Top 10** para C#.
- **Secretos:** credenciales, llaves y tokens escritos en el código.
- **Infraestructura como código:** Terraform, Docker, Kubernetes, CloudFormation, Ansible y workflows de GitHub Actions.
- **Confiabilidad, mantenibilidad y duplicación.**
- **Cobertura de pruebas:** de líneas y de condiciones, a partir de las pruebas que ejecuta el pipeline.

CON ADVANCED SECURITY

Seguridad de las dependencias

- **SCA:** vulnerabilidades conocidas (CVE) en las librerías de terceros, priorizando las que el código realmente usa.
- **Paquetes maliciosos** entre las dependencias.
- **Licencias:** políticas de licencias permitidas.
- **SBOM:** inventario exportable de todas las dependencias.
- **SAST avanzado:** vulnerabilidades que nacen de la interacción entre el código y las librerías open source; disponible para C#/.NET.

CON PLAN ENTERPRISE

Reportes frente a estándares de seguridad

- **Reportes de cumplimiento:** qué hallazgos de cada proyecto incumplen estándares como **OWASP Top 10**, **CWE Top 25** o **PCI DSS**, el estándar de seguridad para pagos con tarjeta. Listos para el área de seguridad.
- **Una sola vista:** todos los proyectos de Viva juntos, aunque estén en distintas organizaciones de GitHub.

Lo que no hace: no ejecuta la aplicación, así que no es DAST, IAST ni prueba de penetración; esas pruebas se hacen con otras herramientas. **En este servicio** configuramos las reglas .NET y el filtro de calidad; secretos e infraestructura como código ya vienen con SonarQube Cloud, y Advanced Security y el plan Enterprise se suman cuando Viva lo decida. Planes en la **documentación oficial**.

ESTADO ACTUAL

El equipo de desarrollo de Generic API no tiene acceso a la herramienta de calidad

DÓNDE ESTÁ

En la infraestructura de un tercero

La herramienta de calidad, SonarQube, vive en **sonarqube.ezyflight.se**: un dominio de Ezy, administrado por Ezy. Cada cambio de código enlaza ahí (por ejemplo, #2511).

QUÉ VE EL EQUIPO

Solo un semáforo y un número

El equipo de desarrollo de Generic API no tiene acceso: ve si el cambio pasó el filtro de calidad y cuántos problemas tiene, pero no cuáles ni dónde están.

QUÉ IMPLICA

Se desaprovecha la herramienta

Lo que no se ve, no se corrige. Y cualquier cambio de reglas o de accesos depende de pedírselo a un tercero.

Además, la revisión automática actual de Generic API **no ejecuta las pruebas unitarias** ni **bloquea**: un cambio con problemas detectados puede llegar igual a la rama principal.

LO QUE ESTO CUESTA HOY · SEPTIEMBRE 2026

Problemas que llegan a la rama principal y retrabajo en cada revisión

9 de 20

cambios llegaron a la rama principal con el filtro de calidad en rojo

20 problemas nuevos detectados por la herramienta, sin que se mencionaran en las revisiones.

0 %

del código nuevo con pruebas unitarias medidas

La revisión automática no ejecuta las pruebas unitarias, así que no se mide qué parte del código nuevo está probada.

46 %

de los cambios comentados, por estilo o convenciones

12 de 26. Son revisiones que una regla automática hace sola, sin ocupar a un revisor.

Revisión manual de lo que una máquina ya detecta

Cuatro tipos de comentario de los revisores los detectan reglas automáticas. Cada uno es tiempo de revisión y un ciclo más de corrección.

Fuente: cambios de código (PRs) de Generic API de septiembre de 2026 y sus revisiones en GitHub, consulta del 8 oct 2026. Enlaces a cada uno en el anexo (slide 16).

EL OBJETIVO

Qué queda funcionando en 15 días hábiles

Objetivo: que Viva tenga **su propio SonarQube**, con **reglas comunes para todos sus proyectos .NET** y un **filtro de calidad por defecto acordado con Viva**; que **Generic API ya lo aplique**, bloqueando los cambios que no cumplen; y que **cualquier proyecto nuevo se sume siguiendo una guía**, sin redefinir reglas ni filtro.

SE COMPRUEBA

Un cambio que no cumple, no se integra

En Generic API, un cambio de prueba que no pasa el filtro de calidad queda en rojo y GitHub no permite integrarlo. Uno que cumple, pasa.

SE COMPRUEBA

Las reglas y el filtro son los acordados

El perfil de reglas .NET y el filtro de calidad por defecto del Sonar de Viva coinciden con lo que Viva aprobó por escrito.

SE COMPRUEBA

Un proyecto nuevo se suma con la guía

Siguiendo solo la guía, un equipo conecta su proyecto .NET al Sonar de Viva desde GitHub Actions y hereda las reglas y el filtro por defecto.

LA PROPUESTA · PASO 1

Una herramienta de calidad de Viva, para todos sus proyectos

Las reglas de calidad dependen del lenguaje, no del proyecto. Viva las define una vez, las aplica a todos sus proyectos y decide quién tiene acceso, sin depender de un tercero.

DEFINE VIVA

Las reglas de calidad de Viva

Un conjunto de reglas por lenguaje y un mismo filtro de calidad, aprobados por Viva.

→

PRIMERO

Generic API

Donde se configura y se prueba en este servicio.

Otros proyectos .NET de Viva

Usan las mismas reglas, sin redefinirlas.

Proyectos en otros lenguajes

Se suman con las reglas de su lenguaje, bajo el mismo criterio.

BASE DE ESTA PROPUESTA

En la nube: SonarQube Cloud

Servicio administrado por SonarSource, bajo una organización de Viva. Sin servidores que mantener. 15 días hábiles.

ALTERNATIVA · UNA SEMANA MÁS

En infraestructura propia

En servidores y dominio de Viva, con edición Developer o superior. Si la configuramos nosotros, suma 5 días hábiles (slide 13).

LA PROPUESTA · PASO 2

Cada cambio pasa por el filtro antes de que lo vea una persona

1

Compilar

¿El código compila? Si no, el cambio se detiene.

BLOQUEA

2

Pruebas unitarias

¿Pasan todas las pruebas unitarias? Una prueba unitaria rota detiene el cambio.

BLOQUEA

3

Análisis

¿Qué problemas nuevos hay? El detalle queda en el cambio, con el enlace a cada problema.

INFORMA

4

Filtro de calidad

¿Cumple el estándar de Viva? Si cumple, pasa a la revisión de una persona; si no, no se puede integrar.

BLOQUEA

Propuesta inicial del filtro

Pruebas unitarias que recorran al menos el 80 % del código nuevo · ningún defecto ni vulnerabilidad nueva · problemas de mantenimiento dentro del límite acordado · poco código duplicado (≤ 3 %).
Solo se exige al código nuevo de cada cambio: el código existente no frena el trabajo. Es el punto de partida: Viva aprueba los umbrales. Como hoy la cobertura no se mide, recomendamos que solo informe las primeras semanas y que Viva decida cuándo pasa a bloquear. Quedan como filtro por defecto para todos sus proyectos.

BENEFICIOS

Menos retrabajo, menos riesgo, más control

Viva Aerobus

- Ningún cambio llega a la rama principal sin pasar el filtro, salvo un salto de emergencia autorizado por Viva.
- Los problemas dejan de acumularse: se controla lo nuevo sin frenar por lo existente.
- Cambia reglas y da accesos sin pedírselo a un tercero.
- Si cambia un proveedor, el control de calidad y el historial que se genere desde ahora se quedan en Viva.

Revisores

- Dejan de corregir a mano lo que una máquina detecta.
- Dedican su tiempo a diseño y negocio.
- Un solo criterio de calidad, igual para todos los cambios.

Equipo de desarrollo

- Ve cada problema y dónde está, desde el propio cambio.
- Sabe si su cambio cumple antes de que lo revise una persona.
- Menos devoluciones y menos idas y vueltas por cambio.

HOY

9 de 20 cambios de septiembre llegaron a la rama principal con el filtro de calidad en rojo, sin pruebas unitarias medidas.

CON EL CONTROL

0 cambios llegan a la rama principal sin pasar las pruebas y el filtro, salvo saltos de emergencia autorizados por Viva y registrados.

PLAN DE TRABAJO

Tres semanas, con tres hitos verificables



DÍA 8

Viva aprueba reglas y filtro

Nuestro plan prevé la aprobación por escrito ese día. Si aún no llega, queda configurada la propuesta inicial y Viva la ajusta después.

DÍA 12

Generic API bloqueando

El pipeline falla si un cambio no pasa el filtro, y GitHub no deja integrarlo.

DÍA 15

Entrega

Demostración con un cambio en rojo bloqueado y uno en verde, guía validada y sesión de entrega.

PRECONDICIONES PARA PRESTAR EL SERVICIO

Lo que Viva decide y habilita

SONAR

En SonarQube Cloud

- **Aprobación de seguridad** para analizar su código en la nube.
- **La organización de Viva**, con **plan Team o superior** (lo contrata Viva) y un administrador para Tech and Solve.
- **Lectura del Sonar de Ezy** para exportar las reglas y el filtro actuales; sin ella, partimos del perfil recomendado por Sonar (Sonar way).
- **La lista de equipos y personas** con acceso, y su rol.

GITHUB

En GitHub

- **Administración del repositorio** de Generic API: workflows, secretos y reglas de protección de ramas.
- **La app de SonarQube Cloud** instalada en la organización de GitHub de Generic API, hoy de Ezy.
- **Permiso para integrar** el cambio del pipeline en Generic API.
- **Un repositorio de prueba** para la guía y el bloqueo.

DECISIONES

Lo que Viva decide

- **Un responsable** con disponibilidad para aprobar reglas y filtro en las dos primeras semanas.
- **Qué ramas se protegen: master** y las que indique.
- **Quién puede saltarse el bloqueo** en una emergencia.
- **Que Generic API se analice solo** en el Sonar de Viva.
- Que corregir hallazgos y escribir pruebas sea parte de cada tarea.

SI ELIGE SONAR PROPIO

En su infraestructura

- **El servidor o la cuenta de nube**, con acceso de administración.
- **El dominio, el certificado y la licencia** Developer o superior, ya comprada.
- **Sonar alcanzable desde GitHub Actions**: publicado en internet o con runners propios en la red de Viva.
- **Permiso para crear la GitHub App** de Sonar en la organización de Generic API.
- **Viva opera el servidor** después de la entrega.

Supuestos: todos los accesos y permisos, incluidos los que dependen de Ezy, se entregan antes de arrancar; los días hábiles cuentan desde ese momento. El pipeline se integra solo en Generic API; otros proyectos se suman con la guía o se cotizan aparte. Si una prueba unitaria no corre en el pipeline, se documenta y el bloqueo se activa con las que sí corren. No incluye corregir hallazgos existentes ni escribir pruebas unitarias.

LA INVERSIÓN · SERVICIO LLAVE EN MANO

15 días hábiles, llave en mano

TIEMPO APROXIMADO DE IMPLEMENTACIÓN

15 días hábiles

Tres semanas con SonarQube Cloud, desde que se cumplen las precondiciones (slide 11). Con Sonar propio, 20 (slide 13).

COSTO

XXX

Incluye los cuatro entregables. Acompañamiento opcional en la slide 14.

1

Sonar de Viva con reglas .NET comunes

Organización de Viva en SonarQube Cloud, con un perfil de reglas .NET por defecto para todos los proyectos y los accesos de los equipos que Viva indique.

2

Reglas y filtro por defecto, aprobados por Viva

El perfil de reglas .NET y los umbrales del filtro que apruebe Viva o, sin aprobación, la propuesta inicial; configurados por defecto para todos los proyectos.

3

Generic API integrado y bloqueando

Su pipeline de GitHub Actions compila, prueba y analiza cada cambio, y falla si no pasa el filtro. Solo el grupo que Viva defina puede saltarse el bloqueo en una emergencia.

4

Guía de integración de proyectos nuevos

Paso a paso y una plantilla de workflow de GitHub Actions para conectar un proyecto .NET al Sonar de Viva. Con sesión de entrega.

ALTERNATIVA · SONAR EN INFRAESTRUCTURA PROPIA

Sonar propio: una semana más si lo configuramos nosotros

TIEMPO APROXIMADO DE IMPLEMENTACIÓN

20 días hábiles

Cuatro semanas: una para montar el Sonar de Viva y las tres del servicio base.

COSTO

yyy

Los mismos cuatro entregables, más el Sonar de Viva instalado y documentado.

LO QUE HACEMOS EN LA SEMANA ADICIONAL

- **Instalar SonarQube**, edición Developer o superior, en contenedores, con su base de datos PostgreSQL.
- **Publicarlo en el dominio de Viva con HTTPS**, detrás de un proxy inverso con el certificado de Viva.
- **Activar la licencia** y configurar el inicio de sesión y los grupos de los equipos.
- **Conectarlo con GitHub** para que el resultado aparezca en cada cambio.
- **Respaldo programado** de la base de datos y **manual de operación**: arranque, actualización y restauración.

QUÉ GANA VIVA

- **Los resultados del análisis** y su historial quedan en la infraestructura de Viva.
- **Control total** del servidor, las versiones y los respaldos.
- **Las mismas reglas, filtro y guía** que con SonarQube Cloud.

OPCIONAL · ACOMPAÑAMIENTO

Una o dos semanas de acompañamiento con el bloqueo ya activo

DURACIÓN

1 o 2 semanas

Justo después de la entrega, a demanda de Viva. Viva elige la duración.

COSTO

zzz por semana

Aparte del servicio base. Aplica igual con SonarQube Cloud o con Sonar propio.

QUÉ INCLUYE

- **Resolver dudas** de los equipos sobre hallazgos, cobertura y por qué un cambio quedó bloqueado.
- **Revisar falsos positivos** y proponer a Viva ajustes de reglas o umbrales; se aplican solo con su aprobación.
- **Atender fallas del pipeline** que no vengan del código: configuración, secretos o tiempos de ejecución.
- **Acompañar a un primer proyecto nuevo** mientras se integra con la guía.
- **Un resumen semanal para Viva:** cambios bloqueados, saltos de emergencia usados y cobertura del código nuevo.

POR QUÉ CONVIENE

- Los primeros días con el bloqueo activo concentran las dudas y los ajustes.
- Los equipos adoptan el filtro con respuesta rápida, en lugar de buscar cómo saltarlo.
- Viva decide los ajustes con datos de las primeras semanas de uso real.

DESPUÉS DE GENERIC API

Una ruta para crecer sobre la misma base

1

Sumar proyectos .NET

Cada equipo conecta su proyecto con la guía y hereda las reglas y el filtro de Viva, sin redefinir reglas ni filtro.

→

2

Sumar otros lenguajes

Un perfil de reglas por lenguaje, bajo el mismo criterio y el mismo filtro de calidad.

→

3

Ampliar la seguridad

Advanced Security para las dependencias y, con el plan Enterprise, reportes frente a estándares como **PCI DSS** (slide 3).

Cada paso lo decide Viva, cuando lo necesite, sobre la base que deja este servicio. Tech and Solve puede acompañar cualquiera de ellos.

Los cambios de código que respaldan estas cifras

9 de 20 · Llegaron a la rama principal con el filtro en rojo

#2421 #2467 #2484 #2487 #2488 #2493 #2506 #2509 #2516

12 de 26 · Comentarios de estilo o convenciones

#2421 #2467 #2478 #2484 #2487 #2488 #2494 #2499 #2504 #2508 #2511 #2516

Comentarios que detecta una regla automática

- **#2516** · parámetro sin uso · Sonar S1172
- **#2467** · métodos idénticos · Sonar S4144; nombre de campo · .editorconfig
- **#2494** · **Array.Empty** · analizador .NET CA1825

PRs de Generic API de septiembre de 2026 en GitHub (EzyWebwerkstaden/VivaAerobus.Generic.Api), consulta del 8 oct 2026. Ningún revisor menciona Sonar en las revisiones ni en los comentarios de los 28 PRs del periodo. Un PR puede estar en varios grupos.